DeepTrustxAI Cloud Attack Paths and Evidence-Driven Defense Workshop

DeepTrustxAI

Cloud Attack Paths and Evidence-Driven Defense

Two-day authorized multi-cloud security workshop

AWS · Azure · GCP · DigitalOcean · Kubernetes · IaC · CI/CD · GRC

Workshop Promise

Think in attack paths

Connect exposure, identity, workload, data, and control-plane impact.

Prove with evidence

Compare manual lab observations with scanner and connector output.

Finish with controls

Map findings to owners, remediation, control status, and closure proof.

> The goal is not to collect more findings. The goal is to explain the most important path, prove it safely, and close it permanently.

Learning Outcomes

By the end of the workshop, participants can:

- Explain a multi-step cloud attack path without relying on provider jargon.
- Identify high-risk weaknesses across IAM, storage, metadata, serverless, data, Kubernetes, IaC, CI/CD, and AI automation.

- Validate a condition inside an **authorized disposable lab** and compare it with scanner output.
- Normalize evidence using a connector contract with `tenant_id` and scan lineage.
- Convert findings into control status, remediation ownership, and audit-ready proof.
- Deliver a five-minute leadership briefing focused on business impact and action.

Format and Team Roles

Item	Workshop design
Duration	2 days, 8 hours per day including breaks
Level	Intermediate to advanced
Delivery	Instructor-led, lab-heavy, team-based
Lab model	Disposable accounts/projects, namespaces, and local clusters only
Team roles	Cloud operator, investigator, evidence owner, dashboard owner, presenter
Final output	Attack path, evidence bundle, scanner validation, control mapping, remediation brief

---

Rules of Engagement

- Use only the target list and tenant assigned by the instructor.
- Do not scan public targets, third-party systems, personal accounts, or production environments.
- Stop immediately when an asset falls outside the documented lab boundary.
- Never place a real production secret inside a vulnerable fixture.
- Capture only the evidence needed; redact tokens, personal data, and sensitive values.
- Keep budgets, quotas, expiry tags, and cleanup workers active.
- Rotate or destroy lab credentials after completion.

If it is not owned, isolated, approved, and recoverable, it is not a workshop target.

Training Lab Architecture

Vulnerable LabIsolated cloud account, project, namespace, or IaC bundle

Scanner WorkerAWS, GCP, Kubernetes, IaC, web, secret, or dependency workflow

ConnectorNormalize source output and preserve scan lineage

Evidence ProcessorValidate tenant, deduplicate, store artifact, map controls

GRC DashboardRisk, owner, status, remediation, and audit proof

Decoupled

Heavy scans run separately from the portal.

Tenant-aware

Jobs, findings, evidence, assets, and credentials carry tenant context.

Recoverable

Labs have reset, teardown, budget, and TTL controls.

Common Evidence Contract

```
{
  "tenant_id": "tenant_demo_001",
  "source_system": "aws_scanner",
  "scanner_type": "cloud",
  "scan_job_id": "scan_001",
  "asset_id": "aws:s3:::lab-artifacts",
  "finding_id": "public_storage_001",
  "severity": "high",
  "control_ids": ["DATA-04", "IAM-02"],
  "evidence_type": "policy_snapshot",
  "evidence_uri": "evidence://tenant_demo_001/scan_001/policy.json",
  "status": "open",
  "remediation": "Restrict public access and require explicit principals."
}
```

Never include raw credentials in findings. Store an encrypted tenant-scoped credential reference instead.

Two-Day Module Plan

Day 1: Exposure to identity	Day 2: Platform depth to governance
M0 Orientation and setup	M6 Containers and Kubernetes
M1 Multi-cloud attack-path mindset	M7 IAM escalation graph
M2 Recon to first foothold	M8 Provider-specific kill chains

Day 1: Exposure to identity	Day 2: Platform depth to governance
M3 Storage and artifact exposure	M9 CI/CD, developer platforms and AI
M4 SSRF, metadata and identity	M10 Defenses that work
M5 Serverless and data tier	Capstone investigation and briefing

---

00

Orientation and Setup

Confirm authorization, tenant routing, and the end-to-end evidence workflow

30 minutes · Portal walkthrough · Dry-run job · Evidence validation

---

Module 0 Lab: Prove Tenant Routing

Phase	Participant action	Expected evidence
Scope	Confirm assigned tenant and disposable lab ID	Scope acknowledgement
Queue	Trigger a dry-run scan job	`scan_job.created`
Ingest	Submit a sample evidence record	`evidence.accepted`
Isolate	Attempt lookup using another training tenant	Access denied or no result
Verify	Open the compliance/evidence view	Correct tenant and control context

Success condition: job, finding, artifact, and audit event all resolve to the same `tenant_id`.

01

Multi-Cloud Attack-Path Mindset

Model cloud compromises as connected control failures

60 minutes · Attack graph · Scanner detection points · Control mapping

---

Anatomy of a Cloud Attack Path

ExposurePublic asset, leaked artifact, vulnerable app, or weak trust

IdentityUser, role, service account, managed identity, or token

PrivilegeBroad action, trust edge, role chain, or automation capability

TargetData store, secret, workload, pipeline, or control-plane resource

ImpactDisclosure, persistence, service disruption, or governance failure

> A useful finding explains where the path starts, which identity moves it forward, and what evidence proves the blast radius.

Module 1 Exercise: Build the Graph

Teams receive a short breach story and produce:

Technical graph

Entry point, identity, privilege edge, target, impact, and missing detection.

Evidence map

API response, policy snapshot, log event, scanner finding, artifact hash, and owner.

Discussion prompts

- Which single control would break the largest number of edges?
- Which scanner should have detected the path earliest?
- What would an auditor need to verify closure?

02

Recon to First Foothold

Find inventory gaps and intentional exposure only inside assigned lab scope

90 minutes · Asset inventory · Manual proof · Scanner comparison

---

Recon Evidence Model

Inventory

Asset identifier, provider, region, owner, environment, and expected exposure.

Observation

Service response, policy state, DNS record, or artifact class without collecting secrets.

Validation

Scanner finding, duplicate handling, false-positive note, severity, and control mapping.

Lab targets may include

- Public object storage configured for the exercise
- Exposed test service or debug endpoint
- Stale test DNS record
- Lab-only build artifact
- Asset absent from the expected inventory

Module 2 Lab: Manual vs Scanner

Step	Action	Output
1	Enumerate only assigned lab assets	Asset list
2	Record intended and unintended exposure	Observation worksheet
3	Capture redacted proof	Screenshot or API artifact
4	Run the cloud inventory scanner	Finding export
5	Reconcile misses, duplicates, and severity	Validation notes

Control question: was the root cause missing inventory, incorrect configuration, or excessive identity access?

03

Storage and Artifact Exposure

Trace how buckets, backups, logs, and build artifacts expose sensitive material

75 minutes · Policy review · Artifact classification · Remediation diff

Storage Risk Patterns

Public access

Anonymous or internet-wide read/list permissions.

Cross-tenant trust

Broad principals or shared credentials beyond intended scope.

Artifact leakage

Backups, logs, source maps, environment files, or build output.

Weak evidence handling

Raw sensitive material copied into tickets or chat.

Durable controls

Default-deny access · Explicit principals · Encryption · Retention rules · Secret scanning · Evidence redaction

Module 3 Lab: Policy to Proof

Phase	Participant action	Evidence produced
Review	Inspect the prepared vulnerable storage configuration	Policy snapshot
Classify	Identify artifact type without exposing its value	Data-classification label
Detect	Compare manual result with scanner finding	Finding and lineage
Fix	Draft or apply least-privilege access	Remediation diff
Prove	Rescan and record new state	Closure evidence

Do not copy sensitive artifact content. Use metadata, hashes, and redacted samples.

04

SSRF, Metadata and Cloud Identity

Understand how an application weakness can become runtime-identity exposure

75 minutes · Controlled trace · Effective permissions · Shared ownership

---

Controlled Application-to-Identity Path

Application inputInstructor-provided request path inside the lab

Internal reachabilityApplication can reach a restricted metadata surface

Runtime identityInstance, workload, or managed identity becomes relevant

Effective permissionsThe attached role defines the actual blast radius

Control responseApp fix, metadata hardening, egress restriction, least privilege

> The lab focuses on evidence and remediation, not exploitation of public applications.

Module 4 Evidence and Ownership

Application owner

Validate input handling, destination restrictions, redirects, and server-side request behavior.

Cloud owner

Harden metadata access, reduce runtime permissions, restrict egress, and monitor identity use.

Evidence bundle

- Redacted application route and expected behavior
- Metadata protection configuration
- Attached runtime identity
- Effective permission snapshot
- Scanner output and two-owner remediation ticket

05

Serverless and Data Tier

Identify lateral-movement risk in functions, queues, databases, and secrets stores

60 minutes · Function identity · Sensitive configuration · Control mapping

---

Module 5 Lab: Automation Identity Review

Function or job

Trigger, attached identity, environment configuration, and deployment source.

Data path

Database, queue, object store, or secret store reachable from the workload.

Evidence path

Manual observation, scanner finding, control mapping, and closure proof.

Review questions

- Does the automation identity have more access than the trigger requires?
- Can sensitive values be moved out of environment variables or build logs?
- Is the data service reachable beyond the intended workload boundary?
- Which log or alert would detect abnormal use?

DAY 2

Platform Depth to Governance

Kubernetes, IAM graphs, provider equivalence, CI/CD, AI, controls, and capstone

Scanner validation becomes evidence, ownership, remediation, and executive proof.

06

Containers and Kubernetes

Assess workload, RBAC, network, secret, and drift risk in a disposable cluster

75 minutes · Kubeconfig scan · Live state · IaC comparison

Kubernetes Scanner Coverage

Area	Checks	Evidence
Workloads	Privileged mode, host mounts, risky capabilities, default namespace	Pod/deployment specification
Identity	Service accounts, Roles, ClusterRoles, bindings	Effective RBAC path
Network	LoadBalancer/NodePort exposure, missing NetworkPolicy	Service and policy snapshot
Secrets	Unnecessary mounts and broad namespace visibility	Redacted workload reference
Drift	Live state compared with YAML or Terraform intent	Deployment-to-IaC diff

---

Module 6 Lab: Live Cluster to IaC

1. Connect using the assigned kubeconfig and context.
2. Inventory pods, services, namespaces, RBAC, and network policies.
3. Identify the prepared privileged workload and broad identity path.
4. Compare live objects with the provided IaC manifests.
5. Rank fixes by blast radius, operational impact, and proof requirement.

   Success is not "the scanner produced findings." Success is a defensible priority order with evidence and owners.

07

IAM Escalation Graph

See permissions as graph edges and trust relationships

75 minutes · Identity graph · Dangerous edges · Least-privilege plan

---

Identity Graph Thinking

PrincipalUser, workload, CI token, function, or service agent

Trust edgeAssume, impersonate, bind, delegate, or pass

ActionCreate, update, attach, invoke, deploy, or modify policy

Resource scopeWildcard, project, subscription, account, namespace, or object

ImpactPrivilege expansion, persistence, secret access, or control-plane change

Graph edge fields: principal · action · resource · condition · trust policy · exception reason

---

Module 7 Lab: Mark the Dangerous Edges

Investigation

Build the identity graph, mark escalation edges, and identify the highest-impact reachable resource.

Remediation

Reduce action and resource scope, add conditions, preserve a documented break-glass path, and rescan.

Evidence produced

Identity graph · High-risk permission list · Scanner finding · Exception record · Least-privilege policy diff

---

08

Provider-Specific Kill Chains

Normalize the evidence, not the provider terminology

75 minutes · AWS · Azure · GCP · DigitalOcean · Developer platforms

---

Equivalent Control Points

Control area	AWS	Azure	GCP	DigitalOcean
Identity	IAM role/policy	Entra ID/managed identity	Project IAM/service account	Teams, projects, API tokens
Storage	S3	Blob/storage account	Cloud Storage	Spaces
Runtime	EC2/Lambda/EKS	VM/Functions/AKS	Compute/Functions/GKE	Droplet/Functions/DOKS
Data	RDS/DynamoDB	Azure SQL/Cosmos DB	Cloud SQL/Firestore	Managed databases
Evidence	CloudTrail/config APIs	Activity logs/resource graph	Audit logs/asset inventory	API inventory/service logs

---

Module 8 Exercise: Normalize Four Cases

For each provider mini-case, produce the same fields:

- Tenant and scan-job lineage
- Asset identifier and type
- Finding class and severity
- Identity or exposure root cause
- Evidence type and URI
- Control IDs
- Owner and remediation
- Closure proof requirement

  Provider-specific details belong in metadata. The control title should remain understandable across clouds.

09

CI/CD, Developer Platforms and AI

Treat automation platforms and agents as cloud-adjacent control planes

60 minutes · OIDC · Tokens · Artifacts · Deployment permissions · AI guardrails

---

CI/CD Attack Surface

RepositoryWorkflow definition, branch control, secret references

RunnerBuild environment, logs, cache, artifacts, network access

IdentityOIDC trust, deployment token, cloud role, service account

PlatformEnvironment variables, project settings, deployment control

Cloud targetRuntime, storage, registry, database, or cluster

Key checks: token scope · OIDC audience/subject · protected branches · artifact visibility · deployment approval

---

AI Integration Guardrails

Risk

Agent receives broad cloud credentials, sensitive evidence, or direct scanner/deployment actions.

Containment

Private model endpoint when needed, tenant-scoped tools, redaction, action logs, and approval gates.

Cost

Use small models for summaries, batch findings, cache outputs, and reserve larger models for complex reasoning.

Evidence to retain

Permission boundary · Approved action log · Redacted prompt · Artifact hash · Model/endpoint identifier · Human approval

---

Module 9 Lab: Workflow and Agent Review

Phase	Participant action	Evidence produced
Inspect	Review the prepared workflow and deployment trust	Workflow snapshot
Scope	Identify token, OIDC, and cloud permission excess	Identity finding
Normalize	Submit a CI/CD connector payload	Accepted evidence record
Guard	Define AI tool permissions and approval rule	Boundary recommendation
Prove	Show the action log and tenant context	Audit evidence

10

Defenses That Actually Work

Convert findings into prevention, detection, response, and proof

45 minutes · Control matrix · Remediation ticket · Rescan evidence

---

Control and Evidence Matrix

Layer	Required question	Workshop evidence
Prevent	What stops the weakness from being introduced?	Policy-as-code result, permission boundary, protected branch
Detect	What identifies the condition or abuse?	Scanner run, audit event, drift alert, anomaly detection
Respond	Who owns containment and remediation?	Ticket, severity, due date, exception, rollback or rotation
Prove	What demonstrates closure?	Before/after configuration, rescan, artifact checksum, approval

A control without an owner and evidence requirement is only a suggestion.

CAPSTONE

End-to-End Investigation and Briefing

Find the most important path, prove it, and explain how to close it

60 minutes · Team investigation · Evidence bundle · Five-minute presentation

---

Capstone Scenario

A newly onboarded tenant contains intentional weaknesses across:

IaC

Public exposure, broad IAM, weak labels, or privileged workload.

Cloud IAM

Trust edge or excessive automation permission.

Storage and data

Over-broad access or exposed lab artifact.

Kubernetes/CI

Broad RBAC, exposed service, drift, or deployment token risk.

Teams must select the **highest-risk connected path**, not simply report every finding.

Capstone Deliverables and Scoring

Area	Points	What good looks like
Attack path	20	Correct chain from exposure to impact
Evidence and tenant isolation	20	Redacted artifacts with lineage and correct `tenant_id`

Area	Points	What good looks like
Scanner validation	20	Manual proof reconciled with scanner findings
Control mapping	15	Findings linked to controls and accountable owners
Remediation	15	Practical fix with proof and exception handling
Executive briefing	10	Clear impact, priority, action, and residual risk

---

Instructor Preparation

Lab readiness

Disposable accounts/projects, region restrictions, budgets, expiry tags, reset and teardown scripts.

Platform readiness

Portal, database, object storage, queue, workers, connectors, and health checks.

Evidence fixtures

Known-good scanner outputs, connector payloads, negative tenant tests, and redacted artifacts.

Delivery fallback

Prerecorded demos, sample evidence, solution guide, capstone answer, and scoring sheet.

Dry run: complete the entire workshop at least three days before delivery.

Student Pack

Item	Included material
Lab guide	Authorized steps, scope boundaries, expected evidence, and stop conditions
Cheat sheets	Cloud CLI, kubectl, Terraform, evidence schema, severity guide
Connector examples	AWS, GCP, Kubernetes, IaC, CI/CD normalized payloads

Item	Included material
Hardening checklist	Provider-specific controls mapped to finding classes
Cleanup guide	Resource teardown, credential rotation, cost check, audit export
Reporting templates	Attack path worksheet, remediation ticket, executive briefing

---

Delivery Rollout

Week 1

Freeze syllabus, evidence schema, authorization model, and tenant boundaries.

Week 2

Build and test AWS, GCP, Kubernetes, IaC, and CI/CD fixtures.

Week 3

Run internal dry run with scanners, connectors, GRC, scoring, and cleanup.

Week 4

Deliver, collect feedback, export evidence, and create the improvement backlog.

Acceptance gates

All labs reset cleanly · No production dependency · Tenant tests pass · Evidence appears in GRC · Costs remain bounded

---

Sources and Usage

- DeepTrustxAI logo: official brand asset from deeptrustxai.com/images/darkmode.png
- Curriculum scope reference: public DEF CON Training listing for "Breaking the Cloud Layer - Modern and Practical Attacks on AWS, Azure, GCP, Aliyun, Railway and Vercel"
- CloudGuard project context: scanner workers, evidence connectors, compliance dashboard, tenant-aware architecture, and authorized vulnerable labs
- This deck is original internal training material and is restricted to approved lab environments

---

Find the Path. Prove the Risk. Close the Control.

Scanner findings become useful when they carry tenant context, evidence, ownership, and remediation proof.